

See discussions, stats, and author profiles for this publication at: <https://www.researchgate.net/publication/320259188>

The Goods, the Bads and the Uglies: Supporting Decisions in Malware Detection through Visual Analytics

Conference Paper · October 2017

DOI: 10.1109/VIZSEC.2017.8062199

CITATIONS

14

READS

447

5 authors, including:



Marco Angelini

Sapienza University of Rome

90 PUBLICATIONS 991 CITATIONS

SEE PROFILE



Leonardo Aniello

University of Southampton

64 PUBLICATIONS 2,472 CITATIONS

SEE PROFILE



Simone Lenti

Sapienza University of Rome

25 PUBLICATIONS 221 CITATIONS

SEE PROFILE



Giuseppe Santucci

Sapienza University of Rome

185 PUBLICATIONS 2,820 CITATIONS

SEE PROFILE

The Goods, the Bads and the Uglies: Supporting Decisions in Malware Detection through Visual Analytics

Marco Angelini*

University of Rome "Sapienza"

Leonardo Aniello†

University of Rome "Sapienza"

Simone Lenti‡

University of Rome "Sapienza"

Giuseppe Santucci§

University of Rome "Sapienza"

Daniele Ucci¶

University of Rome "Sapienza"

ABSTRACT

Malware associated with Web downloads is responsible for many attacks trying to execute malicious code on a remote machine. Web browsers are protected by anti-malware utilities that try to distinguish between good downloads and bad downloads, blocking the bad ones and alerting the user. In order to cope with the uncertainty of such a process, very often the final decision is made using suitable thresholds, giving rise to a 3 categories classification: good downloads, bad downloads, and "in the middle" downloads (i.e., the uglies). In this situation, it is possible to involve the user (e.g., the security manager) in the decision loop, presenting him with the details of the decision process in a way he can either be more confident about the system decisions or he can refine what has been done automatically, e.g., promoting an ugly download to a good one. The paper addresses this problem presenting a visual analytics solution supporting the analysis of the classification system presented in AMICO [24], providing the user with a better understanding of the classification decisions and the possibility of changing the classification results. A prototype is available at: <http://awareserver.dis.uniroma1.it:11768/malvis/>.

Keywords: Malware analysis, malware download, malware classifiers, visual analytics

1 INTRODUCTION

Nowadays, many cyber attacks happen by downloading malicious software (see, e.g., [19]) that gives the attacker the chance to get the control on the machine on which the download happened. That pushed for developing systems able to deal with this issue, and several proposals are available for distinguishing good downloads from bad downloads, blocking the bad ones and alerting the user. Modern detection techniques are based on automatic classifiers rather than fixed signatures. In the former case, detecting malicious software is a trade-off matter and very often the judgment on a possible download produces a decision "good" or "bad" that is affected by a degree of uncertainty. In such cases, the final decision is made using a carefully designed threshold. And here the trade-off issue takes place: a very restrictive threshold keeps the user away from safe and potentially interesting downloads and this is particularly challenging when, for some reasons, the user *must* open the download, e.g., to proceed in an institutional activity, like downloading the curriculum vitae of an applicant for a public selection, and not downloading it may produce serious consequences. The other way around, a too permissive threshold will expose the user to a very high risk. To better handle this situation, more sophisticated detection systems

use at least two thresholds, classifying downloads in 3 categories, good downloads, bad downloads, and "in the middle" downloads (i.e., the uglies).

In these situations, it is possible to involve the user (e.g., the security manager) in the decision loop, presenting him with the details of the decision process in a way he can either be more confident about the system decisions or he can refine what has been done automatically, e.g., promoting an ugly download to a good one. The complexity of this task calls for a visual solution.

Information visualization has been long used in the context of data mining (see, e.g., [16]) and more recently visual analytics has been used in the context of machine learning (see, e.g., the survey in [4]), with the main goal of allowing the user to understand the algorithmic process decisions.

The contribution of the paper is in this direction: it presents a novel visual analytics system supporting the analysis of the classification system presented in AMICO [24] that automatically classifies malware in live Web traffic using download provenance information. The system allows for:

- observing the download traffic in real time, producing an overview of the geographical provenance of the downloaded items;
- observing the decisions made by the classifier, and the relationships existing among the selected features in order to get a general overview of the classifier performances and feature relevances; that can lead to decisions about the classifier (e.g., retrain it) or features (e.g., exclude one feature from the classification process);
- analyzing the decisions made by the classifier inspecting details about a single decision, e.g., the random forest and the features Radviz plot, to understand the reasons of the actual decision; that can lead either to overrule or confirm automatic decisions.

The paper is organized as follows: Section 2 presents the ideas behind the innovative AMICO system, Section 3 discusses some related proposals; Section 4 presents the implemented system; Section 5 presents the capabilities of the visual analytics solution through a comprehensive case study; finally, Section 6 draws some conclusions and presents an outlook for future work.

2 APPLICATION DOMAIN

In the literature, malware detection approaches are commonly based on static or dynamic analysis, see, e.g., Gandotra *et al.* [11]. While static analysis focuses only on the content of the binary code that is inspected without running it [28] [3] [22] (e.g., header fields, embedded strings in plain text, etc.), dynamic analysis observes the behavior of the sample when it is executed. The type of used analysis affects both accuracy and efficiency of the overall detection process: static analysis is much faster than dynamic analysis, but generally provides lower accuracy. Hybrid approaches exist, which combine static and dynamic analysis to improve accuracy even more.

*e-mail:angelini@dis.uniroma1.it

†e-mail:aniello@dis.uniroma1.it

‡e-mail:lenti@dis.uniroma1.it

§e-mail:santucci@dis.uniroma1.it

¶e-mail:ucci@dis.uniroma1.it

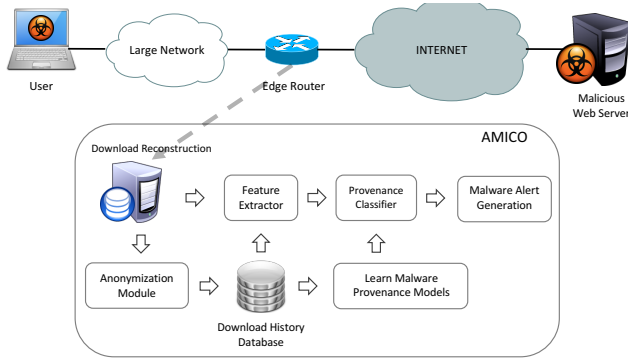


Figure 1: The AMICO framework architecture

The scenario we consider in this paper regards the protection of (the hosts of) a specific network from malicious files downloaded via HTTP traffic. A fundamental requirement in this scenario is a low intrusiveness of the detection approach, which at most should introduce negligible increase of download latency. Meeting this requirement obviously makes the dynamic approach not feasible at all, and that raises the issue that static analysis alone does not provide sufficient guarantees about detection accuracy. Along this direction, one of the most innovative and alternative approaches is proposed in [24]: a framework for malware detection that classifies downloaded items using download characteristics (e.g., IP, url structure, etc.) in live Web traffic, named AMICO (Accurate Malware Identification via Classification of live network traffic Observations).

Figure 1 depicts the fundamental modules: AMICO has been designed to be deployed at the edge of a monitored network (i.e., the *Edge Router* in the figure) to intercept all the incoming and outgoing traffic. Once the framework detects the download of specific files (e.g., executables, PDFs, compressed files, etc.), the *Download Reconstruction* reconstructs the HTTP conversation occurred between the client downloading the file and the server where such file is stored. The reconstruction of the messages exchanged between client and server allows AMICO to extract the metadata characterizing the download patterns of interest. These metadata are then stored in the *Download History Database*, after an anonymization phase carried out by the *Anonymization Module* on clients' IP addresses.

The *Feature Extraction* module generates a feature vector for each download, on the basis of both the extracted metadata and the historical information retrieved from the *Download History Database*. The *Provenance Classifier* takes these feature vectors in input and outputs a *malware score* ranging from 0 to 1, which represents the likelihood that a downloaded file is malicious. The decision on whether a file is to be marked as malware or not is taken by the *Malware Alert Generation*, and is based on a threshold τ : if the malware score is greater than τ then the file is judged as malicious and an alert is triggered. In [24], the threshold value has been set to $\tau = 0.4$ so as to minimize the AMICO's false positive rate.

One key aspect lies in the provenance classifier training. Indeed, AMICO needs a large amount of labeled download events (i.e., tagged as malicious or benign) to be used as ground truth to train the classifier itself. Besides the labels, since AMICO also employs historical features, a bootstrap phase is required to collect enough download metadata in the *Download History Database*. It is stated [24] that AMICO needs a bootstrap phase in the order of months to gather the necessary amount of historical data. After that bootstrap phase, it is possible to properly train the provenance classifier (i.e., *Learn Malware Provenance Models* in the figure). AMICO uses a random forest classifier that builds a set of 50 decision trees to determine if a file is malicious or not. According to the weighted

majority of the votes expressed by these decision trees, the classifier outputs the malware score.

3 RELATED WORK

Malware detection is a fundamental task that allows to distinguish between legitimate and malicious software and many approaches have been proposed in the literature to detect malware. Given a file f , a malware detection algorithm outputs whether f is either benign or malicious.

The combination between visual analytics and machine learning is a topic of research that finds contributions as early as 2009 [10] [4]; which tasks this combination should support, having the human be able to interact with the machine learning process [15], or being able to identify inconsistencies or improvements to be made for training phase [13] [12] is still an open question. However, among the others, the task of understanding the decision process coming from a machine learning algorithm is progressively making its way as a central topic to support. Examples, among many others, can be found in [1], where preliminary visual solutions are proposed to support the expression and experimentation with machine learning algorithms; these preliminary efforts are then refined in [21] where a full-fledged visual analytics environment is proposed to cope with neural networks. Krause *et al.* [17] provide an environment, *Prospector*, where a data scientist can explore the feature space of a classifier, understanding how and why specific data points are predicted as they are. In [18], Laurenza *et al.* design an architecture for analyzing malware through machine learning techniques and envision a visual analytics layer to monitor and control analysis processes. However, as best summarized in [8], "While progress has been made, the tactful combination of machine learning and data visualization is still under-explored".

This paper focuses on the task of inspecting the classification steps of a malware detection classifier based on the random forest algorithm [5] to understand how and why elements have been classified as they are. While different contributions exist combining visual analytics with malware analysis [26], automatic classifiers, see, e.g., [20] [6], and decision trees in particular, see, e.g., [2] [23], only few of them cope directly with random forests. The work in [7] by Breiman and Cutler allows for visualizing a random forest; however, it only accepts numerical features and only support visualizations for single features of the forest; on the contrary, our proposal integrates the various functionalities in the same interactive visualization. Yang *et al.* [27] propose a 3-D visualization of a random forest where each decision tree is represented as a real-life tree. Our approach, instead, uses a small multiple visualization representing the whole forest and providing details on demand, zooming on a single tree (similar to clusters exploration provided in [9]). While the approach in [27] does not scale to large number of trees (occlusion problems), our approach is scalable by increasing the degree of miniaturization while preserving the conveyed information. The proposals in [2] and [23] provide contributions on interactive construction and exploration of decision trees, while Van *et al.* [25] propose a visual analytics approach allowing an interesting and detailed representation of a single decision tree; however, while in all these papers the focus is mainly on interactively constructing and analyzing the decision trees, in our paper the focus is on analyzing what has been already produced by the algorithm (i.e., the random forest) to monitor the classifier health and understand its decision process. To this aim, a multiple coordinated views approach links the small multiples to the set of classified elements represented on a Radviz [14] based on the features used by the classifier.

4 PROTOTYPE

The concepts and solutions presented in the paper have been implemented in a Visual Analytics Prototype (VAP in the following), that

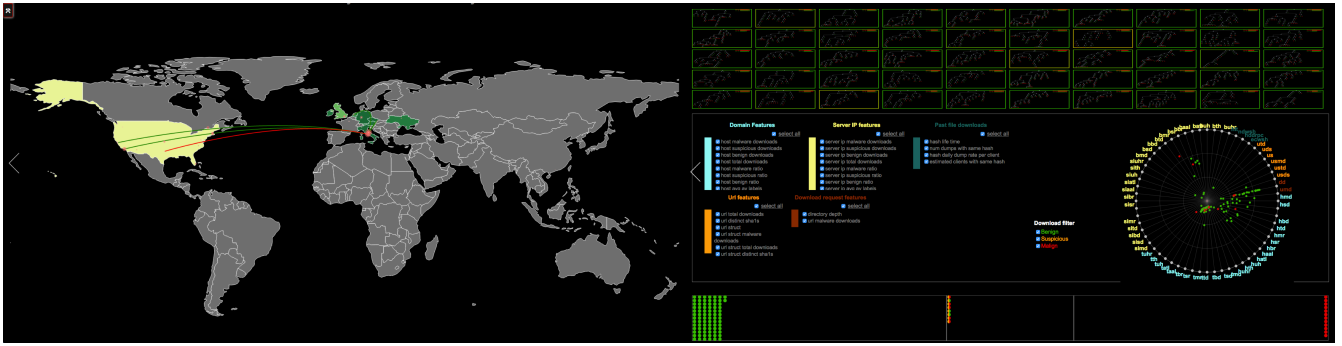


Figure 2: Overview of the Visual Analytics prototype for malware detection. On the left, the Geo-monitoring environment helps the security operators in keeping track of the cardinality and dangerousness of downloaded files. On the right, the decision-explanation & analysis environment allows them to analyze the provenance of the classifier decision and to obtain additional information for the dubious cases.

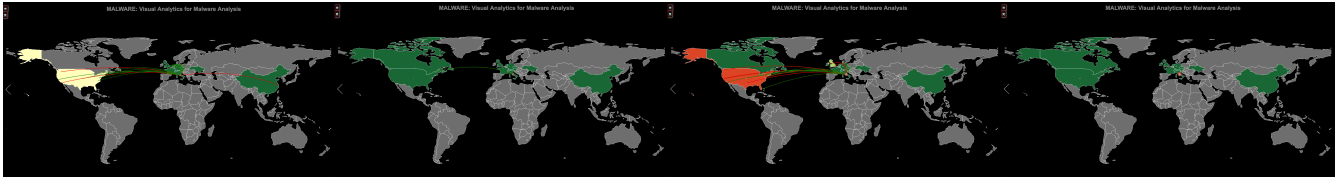


Figure 3: Monitoring phase configured with a high discounting factor. In this sequence of 4 different geo-monitoring visualizations the effects of any event are rapidly discarded, resulting in a visualization that represents only the current time situation.

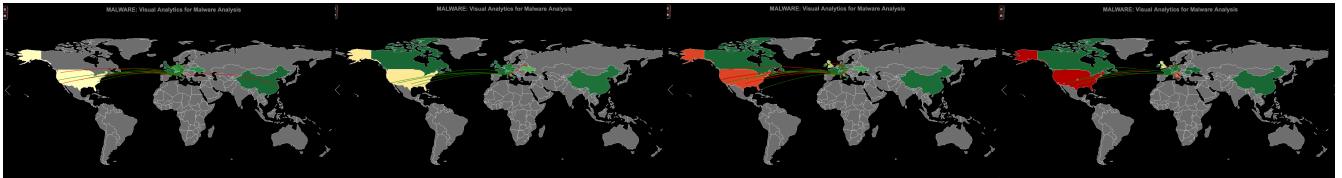


Figure 4: Monitoring phase configured with a low discounting factor. The representation incrementally aggregates the various events, resulting in an historical aggregation of all the contributes from previous events.

is described in this section. The prototype supports three main user tasks, that are:

1. Monitoring the malware: allows the security operator to keep trace of the origin of the downloaded files;
2. Understanding the malware classification: allows the security operator to figure out the motivations behind the classifier decisions on the downloaded files;
3. Analyzing the malware: allows the user to inspect particular instances of downloaded files, looking for additional evidences that can help him in the decision process.

Figure 2 presents the VAP; it is structured in two coordinated environments, the *geo-monitoring environment* and the *decision-explanation & analysis environment*, described in the following subsections.

4.1 Geo-monitoring environment

The first environment presented to the security operator when he launches the VAP is the geo-monitoring environment. It is composed by a geographic visualization where at the center is reported the server monitoring the network. A line connecting the source

IP address to the server IP address, associated to each download event (i.e., a downloaded file from the server), is superimposed on the geographic map. This line is color-coded from red (malicious download) to green (benign download) based on the decision that the AMICO classifier makes on it. If multiple files are downloaded simultaneously from the same origin IP, the line gets colored proportionally to the cardinality of malicious and benign downloaded files. In order to temporally aggregate this information, an eleven degrees color scale ranging from red to green is used to color-code the countries proportionally to the cardinality of malicious downloaded software. In order to cope with color blindness, it is possible to substitute this green-red scheme with a colorblind safe one from the menu. A discounting factor is used in order to mitigate the effect of the past on the actual evaluation of the senders; if it is set to high values, the monitoring will focus on a short term analysis, emphasizing the visualization on the current status (see Figure 3), while if it is set to low values the geo-monitoring environment will become an historical view, spanning from the launch of the system up to the current time instant (see Figure 4).

Every IPs is geo-located on the map with a circle with its size proportional to the number of originated files. The bigger the circle, the more a particular IP is active. In this way, it is possible to recognize more active IPs from countries flagged as malicious senders.

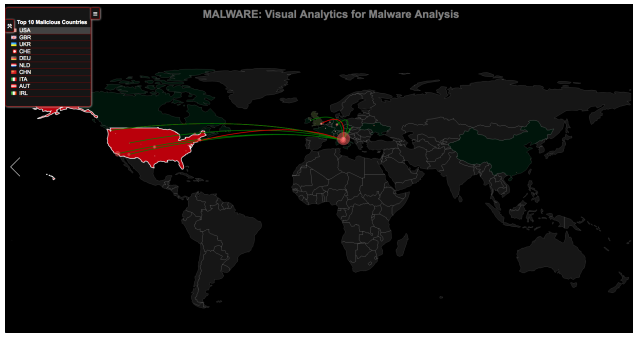


Figure 5: The menu on the upper left allows to browse the top 10 countries whose IPs originated malicious downloads. Clicking on one of them will trigger the list of its IPs, by decreasing number of malicious downloads, and the physical location will be highlighted on the map.

At any time, the security operator can choose to focus his attention on particular areas (led by color coding) or by the aggregated number of malicious download, opening the menu present on the upper left part of the view (see Figure 5). Here is present the top 10 of the countries from which the highest numbers of malicious contents come from. Clicking on one of them will present the list of its IPs (ordered by increasing number of malicious downloads). In this way, the security operator can quickly focus his attention on specific IPs, checking the current number of downloads and the ratio between benign and malicious contents from that IP, represented with an arc diagram visible in Figure 6.

4.2 Decision understanding & analysis environment

The Decision understanding & analysis environment helps the security operator to understand and analyze the decisions made by the automatic classifier. AMICO uses one single sharp threshold 0.4: benign downloads are below, malign downloads are above. In order to deal with uncertainty, we used a configurable non symmetric interval $[0.35, 0.5]$ on the threshold, according to the not centered AMICO threshold, to capture dubious classifications, and we have four possible cases:

1. benign: instances labeled benign with high confidence (threshold below 0.35);

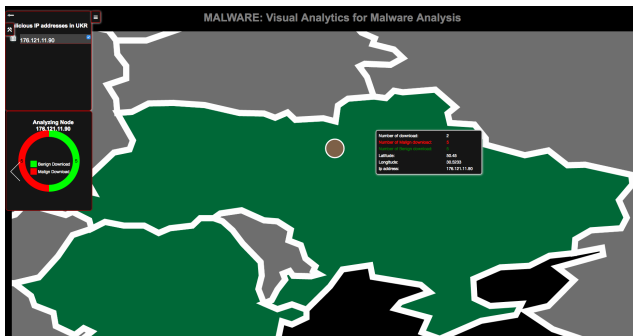


Figure 6: The security operator chooses to inspect the Ukraine (3rd country in the Top 10) and is presented with a list of originating IPs. By browsing them, an arc diagram shows the ratio between malicious and benign downloads while a tooltip shows additional details.

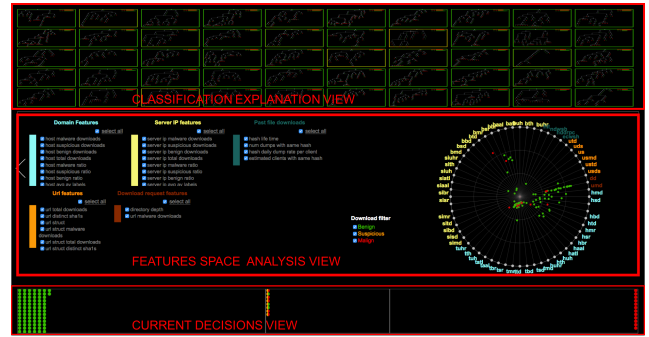


Figure 7: Detailed view of the Decision understanding & analysis environment: on top is visible the Classification explanation view, at the center the Features analysis view, and at the bottom the Current decisions view.

2. malicious: instances labeled as malicious with high confidence (threshold above 0.5);
3. dubious benign: instances labeled benign with a not high enough confidence (threshold in $[0.35, 0.4)$);
4. dubious malicious: instances labeled malicious with a not high enough confidence (threshold in $[0.4, 0.50]$).

In this paper, we consider the case 1 as the Goods (classifier is well confident they are benign), case 2 as the Bads (classifier is well confident they are malicious) and case 3 and 4 as the Uglies (they need additional analysis in order to be rightly classified).

The Decision understanding & analysis environment allows to analyze all these 3 classes through a multiple coordinated views environment composed of 3 main visualizations, visible in Figure 7: the Current decisions view (bottom), the Classification explanation view (top) and the Features space analysis view (center).

4.2.1 Current decisions view

The Current decisions view collects the instances as they are sent and presents the classifier decisions in a compact way: it is organized as 3 different buckets corresponding to the benign files, the malicious files, and the dubious files. The first ones are binned on the left part with a green color code, the second ones are binned on the right with a red color, and the third ones are binned at the center (they are the most important files to check) with a double color code: the orange color represents the low confidence of the classifier, while the red or green represents the current decision that the classifier took on the instance. A detail of the view is visible in Figure 8; from here, by mouse-over, the user can check the current decision and the confidence score for every instance. Clicking on it will trigger the Classification explanation view.

4.2.2 Classification explanation view

The Classification explanation view is a visualization aimed at explaining the process that led the classifier to make a decision on an instance. This view uses a visualization paradigm specific to the particular type of classifier used. In this paper, it is used AMICO as the automatic classifier, that is based on a random forest. The view presents in a compact form the visual representation of each decision tree constituting the random forest of AMICO. By clicking on a tree, it is possible to zoom in on it (see Figure 9) in order to study its composition (the features it uses and the balancing of the tree with respect to number of leaves that correspond to benign decision or malicious decision).



Figure 8: The security operator by mouse-hovering on an instance is able to check the confidence score and highlight the instance in the Features space analysis view.

At the arrival of any new instance or at a later stage it is possible to monitor the descending of the instance on all the trees based on its features. The border of trees boxes is color-coded with a color scale of 10 values ranging from green to yellow to red and represents the aggregated confidence of the contained tree: green means that the tree has always taken a decision in accordance with the final decision of the random forest, red means the opposite, and every intermediate color means that the majority of the decisions are skewed towards one case or the other one. In this way, the security operator obtains a visual way to judge how good is the confidence level of the random forest, and by consequence of the classifier, and even to check if the random forest degraded along the time (when a significant number of trees present a border color different from green), having many trees not in accordance with its decisions (see Figure 9). This can eventually lead to the decision of retraining the classifier.

When the user selects an element from the Current decisions view (or from the Feature space analysis view) the trees that contributed to the decision on that element, i.e. the activated trees, will be highlighted; among them we have trees that made a final decision, represented with a circle with the color code for benign or malicious and trees that stopped at an intermediate node due to a missing feature. Additionally, on all the highlighted trees, the decision paths along the trees are emphasized (blue color), helping in identifying possible anomalies or missing features that can be collected a posteriori for a reclassification attempt (see Figure 10).



Figure 9: Starting from the general visualization of the random forest, the security operator can click on any tree triggering its detailed representation. The tree in the figure shows an imbalance between leaves that lead to benign classification (22) and leaves that lead to malicious classification (14). Additionally, it is possible to spot two trees (annotated by two yellow squares) that present a yellow border, indicating a lower confidence in the past decisions.



Figure 10: With respect to Figure 8 here the security operator chooses to inspect the classifier decision; on top the activated trees with their final state (benign decision, malicious decision, not able to decide) are highlighted. Additionally, when zooming on a single tree, the classification path and the final leaf are shown; the security operator can inspect the various branches of the tree looking for insights.

This refinement will help the security operator in better understanding the confidence of the decision; Figure 12 presents two cases of benign classified files: it is visible that in the first case all the trees made a benign decision, resulting in a really high score, while in the second case the final decision comes from just 2 decision trees, with many others not activated or stopped in a state of not decision due to missing features. If the inspection of the classification process is not enough in order to complement the classifier information and making a decision more confident on a dubious instance, the security operator can choose to analyze more deeply the instance itself in the Feature space analysis view.

4.2.3 Features space analysis view

This area allows for analyzing the instance under examination with respect to both the features space and the past classifications. The view is represented in Figure 7; on the right, we have a graduated Radviz [14] that has for axes the set of features and represents all the instances classified up to the current time. The security operator can inspect them looking for similarities in classification to the one under examination. He can filter downloads for type of instances (benign, malicious, or dubious) and select subsets of features, exploring the feature space and looking for a subset that best matches the inspected instance. Additionally, when the security operator selects an instance



Figure 11: The security operator selects a dubious malicious and chooses to inspect the decision in the Features space analysis view. It is evident that the instance misses almost half of the features, leading to the final decision on just 8 trees.

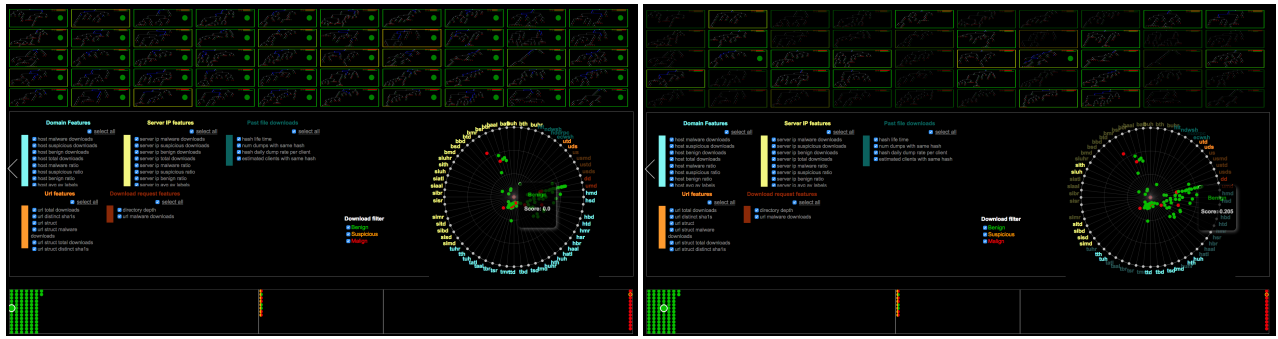


Figure 12: Comparison between two benign instances: while the first one (on the left) presents a complete consensus of all the random forest, the second (on the right) presents the decisions of only 2 trees, with 19 stopped trees and the remaining trees not activated. Additionally, the rightmost activated tree is not even a confident tree. The instance seems to require further investigation.

Table 1: Summary of the files downloaded in the monitored network.

Downloads		
Compressed files	APK	17
	JAR	19816
	RAR	11403
	ZIP	26743
Documents	PDF	174445
Executables	DMG	60
	ELF	784
	EXE	9410

the features that in this instance are missing will be greyed out, in order to better understand which features have been effectively used for the decision (see Figure 11).

This might constitute a guidance for trying to obtain some of the missing ones and attempt a reclassification. The goal of this activity is to spot similar instances to the actual one, to check their decision process in the Classification explanation view and in this way collecting additional information helpful in making a decision for the current instance under examination.

4.3 User tasks support

This subsection explains how VAP can support different analysis workflows, tied to the user tasks introduced at the beginning of this section. The monitoring task (task 1) is supported both by starting from the Geo-monitoring and looking for the distribution of malicious files incoming from specific IP addresses or by monitoring the health state of the classifier using both the Classification explanation and Current decisions views, that provides an overview of the up-to-date state.

The comprehension task (task 2) is supported allowing the user to understand the provenance of the decision (Classification explanation view), which features provide more support to a decision, and which previous instances are similar to the one under investigation (Features space view), where it comes from, how other malicious files obtained from the same IPs behaved, in order to consider the current downloaded malicious files and take mitigation actions (e.g., adding new firewall rules). This view is also supporting the malware analysis (task 3), where, based on missing features or augmented knowledge on how many and how decision trees are activated in the random forest, the security operator can confirm the classifier decision, change it due to particular similarities to previously classified instances, or by inspecting the frequency distribution of malicious files obtained by the source IP of the current one, or trying to obtain information for completing some of the missing features and let the classifier run on the instance again.

Table 2: Summary of the files classified as malicious in the monitored network.

Malware		
Compressed files	APK	0
	JAR	4
	RAR	0
	ZIP	0
Documents	PDF	9
Executables	DMG	1
	ELF	0
	EXE	77

5 CASE STUDY

AMICO has been deployed on a server of the Department of Computer, Control, and Management Engineering “Antonio Ruberti” at Sapienza University of Rome. The server continuously monitors incoming and outgoing network traffic. We have collected 242,678 file download events, from November 2014 to August 2015. Collected downloads include Windows executables, compressed files, and documents. Table 1 summarizes the number of files downloaded in our monitored network.

More than 98% of classified downloads has been judged by AMICO as benign (i.e., the malware score is below the τ parameter discussed in Section 2). Approximately, the remaining 1.7% is categorized as either dubious malicious or malicious. Figure 13 depicts the trend of file downloads classified by AMICO as malicious with very high confidence (malware score ≥ 0.8) during its 9 months of activity. AMICO has detected 91 malicious files which resulted malicious even by checking them on VirusTotal. Details on the file

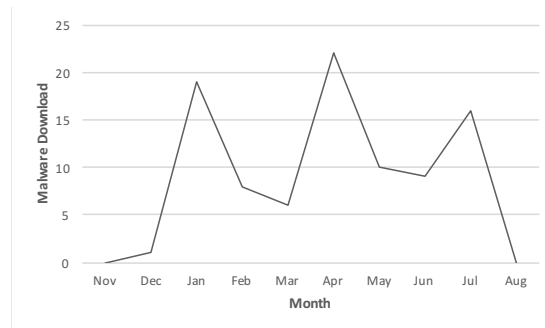


Figure 13: Trend of file downloads classified by AMICO as malicious with very high confidence.

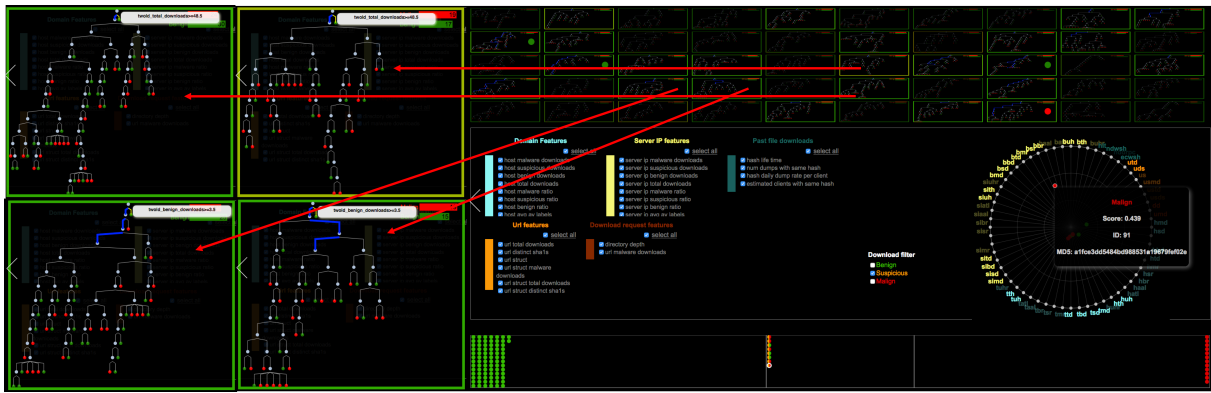


Figure 14: A visual inspection allows to identify a consensus toward a benign decision. By inspecting the Radviz it is visible that the instance is skewed towards Server IP features, missing lot of features in the Domain features. They affect the decisions of at least 4 additional trees, that could bring the final decision toward a confident benign classification.



Figure 15: Identification, confirmation (through visual inspection) and validation (through VirusTotal) of a false positive.

composition, can be found in Table 2.

Using the system for a time span of 9 months from November 2014 to August 2015, we collected a series of findings demonstrating the added information that our solution provides with respect to the plain use of AMICO classifier. As scalability issues in these 9 months, we have not observed download peaks that might cause problems to the security operator monitoring the detection system. The most relevant findings are listed in the following.

The first one regards the inspection of the dubious classified instances: the security operator explores the Feature space analysis view and identifies 2 instances in the upper left quadrant that seem outliers (such outliers are visible in Figure 12 on the right). While the first one is correctly classified as malicious content (good number of activated trees, large consensus of them on malicious decision), the second instance decision is supported only by 4 out of 21 activated trees. Moreover, of these 4, only one makes the decision to classify the instance as malicious, while the other trees are biased towards benign classification. The low number of trees making a decision tell us that the classifier confidence is not high on this decision. The security operator can identify the features that the instance is missing, and among them it is identifiable the feature “second level domain total download” of the Domain Features family (on the bottom of the Radviz, where many others features are missing) and checks that many not activated trees halt the classification on this feature (taking a path that leads to a missing features) (see Figure 14). After the identification of this feature, at a later stage the security operator checks that it changed with respect to the thresholds values, and choose to re-classify the instance. This time the classification shows a much higher confidence score, leading to label it as benign.

The second finding concerns the confirmation on the AMICO classifier decision. The security operator selects another instance, labeled as malicious but with a score of 0.415, really near to the threshold. From the Decision explanation view it is visible that 32 trees were activated, with 12 making decisions split in 7 for benign and 5 for malicious, with many confident trees involved; this would suggest for a possible benign decision. The security operator retrieves the MD5 hash and upload it to VirusTotal. As visible in Figure 15, the file is confirmed benign. A false positive has been identified.



Figure 16: Looking at the Decision explanation view it is clear like in the bootstrap phase the confidence of the random forest is questionable and needs additional inspection.

The third finding regards the status of the random forest during the bootstrap (after the training phase). Figure 16 shows how during the transitory time the random forest presents trees with high variability in the decisions they made. This transitory eventually stops after a time (for AMICO the suggested time is 3 months), allowing the security operator to judge on the decision confidence (see Figure 16).

A fourth finding concerns the case in which the classifier fails to extract features from an instance and some or all of its features are missing. During its 9 months of activity, AMICO failed in extracting features from less than 12% of total file downloads due to possible errors in download reconstruction phase. The majority of these errors is related to compressed file (JARs and ZIPs). In the case in which none of the decision trees are activated for the above reasons, the malware detector will not take a decision and will not alert the security operator. In our solution, an instance not labeled is represented as a complete orange point positioned in the dubious buckets in the Current decisions view (see Figure 17).



Figure 17: Longer time-slice of analysis; In the Current decisions view the security operator can identify 2 orange points, representing instances where the features extraction failed to collect a minimum number of features to let the random forest make a decision.

6 CONCLUSIONS

Detecting malicious software is a trade-off matter and this paper presented a case study based on the AMICO malware detection system, designing and implementing a fully-fledged visual analytics system that aims at presenting the end user with a broader understanding of what is going on behind the scene. The system allows for monitoring the origin of the malware download, for understanding the malware classification decisions made by AMICO thorough the inspection of the details of the random forest, and for inspecting single instances of the dubious downloads, getting further information that can improve the decision process.

The system has been tested in a real environment using AMICO, collecting 242,678 file download events in 9 months, allowing to inspect the downloads origin and the classifier results, rising several insights that have been confirmed by a cross check with VirusTotal.

Concerning future work, we are planning to improve the analysis capabilities of the system adding new functionalities for dealing with the random forest, making more clear the relationships between the decision trees and the used classification features and by investigating on the role each three had in the final decision.

ACKNOWLEDGMENTS

The authors wish to thank Emanuele Palpacelli for his invaluable help in developing the system.

REFERENCES

[1] M. Abadi, A. Agarwal, P. Barham, E. Brevdo, Z. Chen, C. Citro, G. S. Corrado, A. Davis, J. Dean, M. Devin, et al. Tensorflow: Large-scale

machine learning on heterogeneous distributed systems. *arXiv preprint arXiv:1603.04467*, 2016.

[2] M. Ankerst, C. Elsen, M. Ester, and H.-P. Kriegel. Visual classification: an interactive approach to decision tree construction. In *KDD*, 1999.

[3] J. Bai, J. Wang, and G. Zou. A malware detection scheme based on mining format information. *The Scientific World Journal*, 2014.

[4] E. Bertini and D. Lalanne. Surveying the complementary role of automatic data analysis and visualization in knowledge discovery. In *Integrating Automated Analysis with Interactive Exploration Workshop*.

[5] L. Breiman. Random forests. *Machine learning*, 45(1):5–32, 2001.

[6] J. Choo, H. Lee, J. Kihm, and H. Park. ivisclassifier: An interactive visual analytics system for classification based on supervised dimension reduction. In *Visual Analytics Science and Technology*, 2010.

[7] A. Cutler and L. Breiman. Raft: Random forest tool. URL: <http://www.stat.berkeley.edu/users/breiman/RandomForests/> (15.04. 2011), 2011.

[8] A. Ender, W. Ribarsky, C. Turkay, B. Wong, I. Nabney, I. D. Blanco, and F. Rossi. The state of the art in integrating machine learning into visual analytics. In *Computer Graphics Forum*, 2017.

[9] F. Fischer, J. Davey, J. Fuchs, O. Thonnard, J. Kohlhammer, and D. A. Keim. A visual analytics field experiment to evaluate alternative visualizations for cyber security applications. In *Proc. of the EuroVA International Workshop on Visual Analytics*, 2014.

[10] R. Fuchs, J. Waser, and M. E. Groller. Visual human+machine learning. *Transactions on Visualization and Computer Graphics*, 2009.

[11] E. Gandotra, D. Bansal, and S. Sofat. Malware analysis and classification: A survey. *Journal of Information Security*, 5(02):56, 2014.

[12] F. Heimerl, S. Koch, H. Bosch, and T. Ertl. Visual classifier training for text document retrieval. *Transactions on Visualization and Computer Graphics*, 2012.

[13] B. Höferlin, R. Netzel, M. Höferlin, D. Weiskopf, and G. Heidemann. Inter-active learning of ad-hoc classifiers for video visual analytics. In *Visual Analytics Science and Technology*, 2012.

[14] P. Hoffman, G. Grinstein, K. Marx, I. Grosse, and E. Stanley. Dna visual and analytic data mining. In *Visualization*, 1997.

[15] A. Holzinger. Interactive machine learning for health informatics: when do we need the human-in-the-loop? *Brain Informatics*, 2016.

[16] D. A. Keim. Information visualization and visual data mining. *IEEE transactions on Visualization and Computer Graphics*, 8(1):1–8, 2002.

[17] J. Krause, A. Perer, and K. Ng. Interacting with predictions: Visual inspection of black-box machine learning models. In *Conference on Human Factors in Computing Systems*, 2016.

[18] G. Laurenza, D. Ucci, L. Aniello, and R. Baldoni. An architecture for semi-automatic collaborative malware analysis for cis. In *Dependable Systems and Networks Workshop (DSN-W)*, pp. 137–142, June 2016.

[19] L. Lu, V. Yegneswaran, P. Porras, and W. Lee. Blade: an attack-agnostic approach for preventing drive-by malware infections. In *CCS*, 2010.

[20] F. J. Provost, T. Fawcett, et al. Analysis and visualization of classifier performance: comparison under imprecise class and cost distributions. In *KDD*, vol. 97, pp. 43–48, 1997.

[21] D. Smilkov, S. Carter, D. Sculley, F. B. Viégas, and M. Wattenberg. Direct-manipulation visualization of deep networks. In *Workshop on Visualization for Deep Learning*, 2016.

[22] S. Srakaew, W. Piyanuntcharatsr, and S. Adulkasem. On the comparison of malware detection methods using data mining with two feature sets. *Journal of Security and Its Applications*, 2015.

[23] S. T. Teoh and K.-L. Ma. Paintingclass: interactive construction, visualization and exploration of decision trees. In *International conference on Knowledge discovery and data mining*, 2003.

[24] P. Vadrevu, B. Rahbarinia, R. Perdisci, K. Li, and M. Antonakakis. Measuring and detecting malware downloads in live network traffic. In *ESORICS*, pp. 556–573, 2013.

[25] S. Van Den Elzen and J. J. van Wijk. Baobabview: Interactive construction and analysis of decision trees. In *VAST*, 2011.

[26] M. Wagner, F. Fischer, R. Luh, A. Haberson, A. Rind, D. A. Keim, W. Aigner, R. Borgo, F. Ganovelli, and I. Viola. A survey of visualization systems for malware analysis. In *EuroVis-STARs*, 2015.

[27] M. Yang, H. Xu, D. Zhu, and H. Chen. Visualizing the random forest by 3d techniques. *Internet of Things*, pp. 639–645, 2012.

[28] J. Yonts. Attributes of malicious files. Technical report, The SANS Institute, 2012.